

Plan Legal **RGPD** a Coste Cero

GUÍA PRÁCTICA PARA OPERAR SIN ABOGADO AL INICIO

Objetivo: Cubrir los requisitos legales mínimos del RGPD utilizando exclusivamente herramientas gratuitas oficiales (AEPD, INCIBE) y decisiones tácticas de negocio que eliminan la necesidad de asesoría de pago en la fase de arranque.

Para: EsarIA — Javier Delgado Hernández

Fecha: Mayo 2026

Vigencia: Hasta cerrar el 2º o 3er cliente (momento para contratar asesoría legal profesional)



Decisión Táctica Clave: Evitar Datos de Salud

**Regla #1: Tu primer cliente NO puede ser una clínica ni un fisioterapeuta**

Los datos de salud están protegidos bajo la categoría especial del RGPD (Art. 9). Automatizar citas de pacientes implica tratar datos de salud, lo que requiere: Evaluación de Impacto (EIPD), Contrato de Encargado reforzado, y en muchos casos consulta con un Delegado de Protección de Datos. Sin abogado, esto es inviable de forma segura.

**Regla #2: Talleres, gimnasios, academias y comercios son seguros**

Estos sectores manejan datos básicos (nombre, teléfono, email, historial de compras/servicios). Esto es **categoría básica del RGPD** y se cubre con las herramientas gratuitas de la AEPD. No necesitas abogado para operar con estos sectores si sigues este plan.

Impacto en tu pipeline de leads

SECTOR	LEADS ACTUALES	RIESGO RGPD	DECISIÓN
Fisioterapia	8 leads	Alto (datos de salud)	✗ Aparcar hasta tener asesoría legal
Clínica dental	3 leads	Alto (datos de salud)	✗ Aparcar hasta tener asesoría legal
Gimnasio	6 leads	Bajo (datos básicos)	✓ Priorizar como sector #1
Taller mecánico	3 leads	Bajo (datos básicos)	✓ Priorizar como sector #2
Academia	10 en bruto	Bajo (datos básicos)	✓ Ampliar leads operativos
Comercio	0 leads	Bajo (datos básicos)	✓ Buscar 10 leads nuevos

**Cuándo volver al sector clínico**

Cuando hayas cerrado 2-3 clientes en sectores seguros y tengas caja para invertir 200-500€ en una sesión con un abogado de protección de datos en Valladolid. Ese momento probablemente llega tras facturar 1.000-1.500€. No antes.

Herramientas Gratuitas Oficiales

1. Facilita RGPD — AEPD

URL: <https://www.aepd.es/facilita>

Herramienta online gratuita de la Agencia Española de Protección de Datos. Responde un cuestionario sobre tu actividad y te genera automáticamente:

- Cláusulas informativas adaptadas a tu negocio
- Registro de actividades de tratamiento
- Análisis de riesgos básico
- Documento de medidas de seguridad recomendadas

⚠ Importante

Facilita RGPD está diseñada para empresas que tratan datos de **riesgo bajo**. Si marcas que tratas datos de salud, la herramienta te derivará a un proceso más complejo. Por eso es fundamental que tu primer cliente sea de un sector que NO maneje datos sensibles.

2. Guías del INCIBE

URL: <https://www.incibe.es/protege-tu-empresa>

El Instituto Nacional de Ciberseguridad publica guías gratuitas para PYMEs y autónomos que incluyen:

- Plantillas de políticas de privacidad
- Checklist de ciberseguridad básica
- Guías de cumplimiento normativo
- Modelos de cláusulas contractuales

3. Modelos de contrato de encargado (DPA)

La propia AEPD ha publicado directrices sobre el contenido mínimo del contrato de encargado del tratamiento (Art. 28 RGPD). Busca en [aepd.es](https://www.aepd.es) la sección de "Responsable y encargado del tratamiento".

Contenido mínimo que debe tener tu DPA básico:

- Identificación de las partes (tú como encargado, el cliente como responsable)
- Objeto y duración del tratamiento
- Naturaleza y finalidad (ej: "gestión automatizada de recordatorios de cita")

- Tipo de datos tratados (nombre, teléfono, fecha de cita)
- Obligaciones del encargado (confidencialidad, medidas de seguridad, no subcontratar sin autorización)
- Derechos de auditoría del responsable
- Devolución o destrucción de datos al terminar



Opción práctica: DPA incluido en tu contrato de servicios

No necesitas dos documentos separados. Puedes incluir las cláusulas del DPA como un anexo dentro de tu contrato de prestación de servicios. Un solo documento, firmado una sola vez, que cubra servicio + protección de datos.

4. Canal Joven de la AEPD

URL: <https://www.aepd.es/canaljoven>

La AEPD ofrece consultas gratuitas y material educativo. También puedes llamar al teléfono de atención al ciudadano de la AEPD **(900 293 183)** para consultas puntuales sobre cumplimiento sin coste.

Reglas de Oro para Operar sin Abogado

Estas reglas operativas te permiten trabajar de forma legal y segura mientras no tengas presupuesto para asesoría profesional. Síguelas al pie de la letra:

Reglas sobre tecnología y datos

1. **NO conectes ningún LLM (OpenAI, Claude, Gemini) a datos reales del cliente.** La automatización de citas y recordatorios NO necesita IA — es integración pura con Google Calendar + WhatsApp Business. Esto es mucho más limpio legalmente y más fácil de mantener.
2. **Usa solo herramientas con servidores en la UE.** Google Workspace permite elegir región EU. Make tiene opción EU. Si usas n8n, mejor self-hosted en tu máquina o en un servidor europeo.
3. **Los datos siempre en cuentas del cliente, nunca en las tuyas.** Configura todo bajo las cuentas de Google/email del cliente. Tú accedes con un permiso que ellos pueden revocar en cualquier momento.
4. **Guarda solo lo mínimo.** Para un sistema de citas: nombre, teléfono, fecha y hora de cita. Nada más. No guardes DNI, dirección postal ni datos bancarios.
5. **No almacenes nada en tu ordenador personal.** Todo se queda en la nube del cliente o en las herramientas de automatización bajo su cuenta.

Reglas sobre documentación

1. **Usa Facilita RGPD antes del primer cliente.** Genera la documentación base y guárdala.
2. **Incluye cláusulas DPA en tu contrato de servicios.** Usa el modelo del Anexo de esta guía.
3. **Documenta qué herramientas usas y dónde están los datos.** Un simple documento de texto con: herramienta → localización → datos que trata.
4. **Entrega al cliente una ficha de "qué datos se tratan"** al inicio del proyecto. Que firme que lo sabe y lo acepta.

Lo que NO debes hacer nunca

Líneas rojas absolutas (con o sin abogado)

- No envíes mensajes masivos de WhatsApp sin consentimiento previo del destinatario.
- No copies bases de datos de clientes del negocio a tu ordenador personal.
- No uses datos de un cliente para otro cliente ni para tu propio marketing.
- No prometas "cumplimiento total RGPD" — di que aplicas las medidas recomendadas por la AEPD para tu nivel de riesgo.
- No trates datos de menores sin consentimiento parental verificado.

- No ignores una solicitud de derechos ARCO (acceso, rectificación, cancelación, oposición) — informa al cliente inmediatamente.

Flujo recomendado para el primer cliente (sector seguro)

PASO	ACCIÓN	HERRAMIENTA
1	Generar documentación RGPD base	Facilita RGPD (AEPD)
2	Preparar contrato con cláusula DPA incluida	Plantilla propia + modelo AEPD
3	Firmar contrato con el cliente	Firma en papel o email con aceptación
4	Configurar automatización bajo cuenta del cliente	Make (EU) + Google Calendar + WhatsApp Business
5	Documentar herramientas y datos tratados	Documento interno simple
6	Entregar ficha de datos tratados al cliente	PDF de 1 página

Checklist y Timeline

Checklist: antes de cerrar el primer cliente

- ☐ Completar el cuestionario de Facilita RGPD en aepd.es/facilita
- ☐ Descargar y guardar la documentación generada por Facilita
- ☐ Redactar contrato de servicios con cláusula DPA integrada
- ☐ Verificar que Make/n8n está configurado con servidores EU
- ☐ Preparar la ficha de "datos tratados" para entregar al cliente
- ☐ Confirmar que NO se conecta ningún LLM a datos reales
- ☐ Confirmar que el sector del cliente NO es sanitario ni educativo con menores
- ☐ Confirmar que todo se configura bajo cuentas del cliente

Checklist: antes de entregar el proyecto

- ☐ Contrato firmado por ambas partes
- ☐ Ficha de datos tratados entregada al cliente
- ☐ Documentación interna de herramientas y localización de datos
- ☐ Accesos configurados bajo cuenta del cliente
- ☐ Verificar que no quedan datos en cuentas personales de EsarIA
- ☐ Informar al cliente de cómo revocar accesos al terminar

Timeline: cuándo invertir en asesoría legal profesional

MOMENTO	ACCIÓN LEGAL	COSTE ESTIMADO
Cliente 0 (piloto gratuito)	Facilita RGPD + contrato propio con DPA básico	0 €

MOMENTO	ACCIÓN LEGAL	COSTE ESTIMADO
Cliente 1 (primer cobro)	Igual que arriba. Solo sectores de bajo riesgo	0 €
Clientes 2-3 (~1.000-1.500€ facturados)	Sesión con abogado de protección de datos. Revisión de contrato y DPA	150 - 300 €
Primer cliente clínico (tras asesoría)	DPA reforzado para datos de salud + EIPD	300 - 500 €
Alta como autónomo	Asesoría fiscal. Obligatorio antes de emitir primera factura	50 - 100 €/mes (gestoría)

Recurso gratuito de emergencia

Si te surge una duda legal concreta antes de poder pagar un abogado, la AEPD tiene una **línea de atención gratuita: 900 293 183**. También puedes enviar consultas por escrito a través de su sede electrónica. No sustituye asesoría profesional, pero te puede sacar de un apuro puntual.

Resumen ejecutivo

Este plan te permite operar legalmente con tu primer cliente si cumples tres condiciones:

1. **Sector seguro** (taller, gimnasio, academia, comercio — sin datos de salud)
2. **Sin IA conectada a datos reales** (solo integración pura: calendario + WhatsApp)
3. **Todo bajo cuentas del cliente** (tú no almacenas ni procesas nada en tu nombre)